Vulnerabilities Assessment Testing Report

1. Introduction

This report document hereby describes the proceedings and results of a Black Box security assessment conducted against an **AltoroMutual**. The report hereby lists the findings and corresponding best practice mitigation actions and recommendations.

2. Objective

The objective of the assessment was to assess the state of security and uncover vulnerabilities in **AltoroMutual** and provide with a final security assessment report comprising vulnerabilities, remediation strategy and recommendation guidelines to help mitigate the identified vulnerabilities and risks during the activity.

3. Scope

This section defines the scope and boundaries of the project.

Application Name	Home of Acunetix Art Web Application
URL	http://demo.testfire.net

3.1. Assessment Attribute(s)

Parameter	Value
Starting Vector	External
Target Criticality	Critical
Assessment Nature	Cautious & Calculated
Assessment Conspicuity	Clear
Proof of Concept(s)	Attached wherever possible and applicable.

3.2. Risk Calculation and Classification

Following is the risk classification:

Info	Low	Medium	High	Critical
No direct threat to host/ individual user accounts. Sensitive information can be revealed to the adversary.	Vulnerabilities may not have public exploit (code) available or cannot be exploited in the wild. Vulnerability observed may not have a high rate of occurrence. Patch workaround released by vendor.	Vulnerabilities may not have public exploit (code) available or cannot be exploited in the wild. Patch/ workaround not yet released by vendor.	Vulnerabilities which can be exploited publicly, workaround or fix/ patch available by vendor.	Vulnerabilities which can be exploited publicly, workaround or fix/ patch may not be available by vendor.

Table 1: Risk Rating

Summary

Outlined is a Black Box Application Security assessment for **AltoroMutual**

http://demo.testfire.net

The following section illustrates **Detailed** Technical information about identified vulnerabilities.

Total: 6 Vulnerabilities

High	Medium	Low
0	**4**	**4**

1. Information Disclosure (Server Banner)

Reference No:	Risk Rating:
	medium

Tools Used:
Nmap 7.98
Vulnerability Description:
The server is telling everyone exactly what "engine" it uses. Why it matters: An attacker can now look up specific exploits for "Apache-Coyote 1.1." A more secure setup would hide this specific version info (Banner Grabbing protection).
Vulnerability Identified by / How It Was Discovered
nmap -sV -sC -p 1-1023 demo.testfire.ne
Vulnerable URLs / IP Address
http://demo.testfire.net
Implications / Consequences of not Fixing the Issue
The failure to mask server version information provides attackers with a precise vulnerability roadmap, allowing them to bypass the "discovery" phase and move directly to exploitation.
Suggested Countermeasures
Configure the Apache Tomcat server to hide the `Server` header in HTTP responses.
References

Proof of concept:
Automated Analysis:

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC -p 1-1023 demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-19 12:48 -0400
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.49% done
Stats: 0:00:26 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 46.73% done; ETC: 12:48 (0:00:21 remaining)
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.027s latency).
Not shown: 1021 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
|_ssl-date: 2026-03-19T16:49:11+00:00; +2s from scanner time.

Host script results:
|_clock-skew: 1s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.25 seconds
```

2. Absence of Anti-CSRF Tokens

Reference No:	Risk Rating:
CWE ID :352 , WASC ID: 9	**Medium**

Tools Used:

Zaproxy

Vulnerability Description:

CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

Vulnerability Identified by / How It Was Discovered

Manual Analysis

Vulnerable URLs / IP Address

http://demo.testfire.net/login.js
http://demo.testfire.net/feedback.jsp

Implications / Consequences of not Fixing the Issue

Combining XSS with CSRF allows attackers to bypass the browser's "Same-Origin" security and move from simply performing actions to stealing private data. This synergy transforms a standard session-hijacking attempt into a full information disclosure breach by using the victim's full privileges

Suggested Countermeasures

Phase: Architecture and Design

- Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.
  For example, use anti-CSRF packages such as the OWASP CSRFGuard.

- Phase: Implementation
  Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script.

- Phase: Architecture and Design
  Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS.

- Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation.
  Note that this can be bypassed using XSS.

- Use the ESAPI Session Management control.
  This control includes a component for CSRF.

- Do not use the GET method for any request that triggers a state change.

- Phase: Implementation

Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
References
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html

Proof of concept:

URL #1:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:59 GMT
content-length: 8555

<div class="fl" style="width: 99%;">

<h1>Online Banking Login</h1>

<!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
<p><span id="_ctl0__ctl0_Content_Main_message" style="color:#FF0066;font-size:12pt;font-weight:bold;">

</span></p>

<form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
  <table>
    <tr>
      <td>
        Username:
      </td>
      <td>
        <input type="text" id="uid" name="uid" value="" style="width: 150px;">
      </td>
      <td>
      </td>
    </tr>
    <tr>
      <td>
        Password:
```

Fig 1: http://demo.testfire.net/feedback.jsp

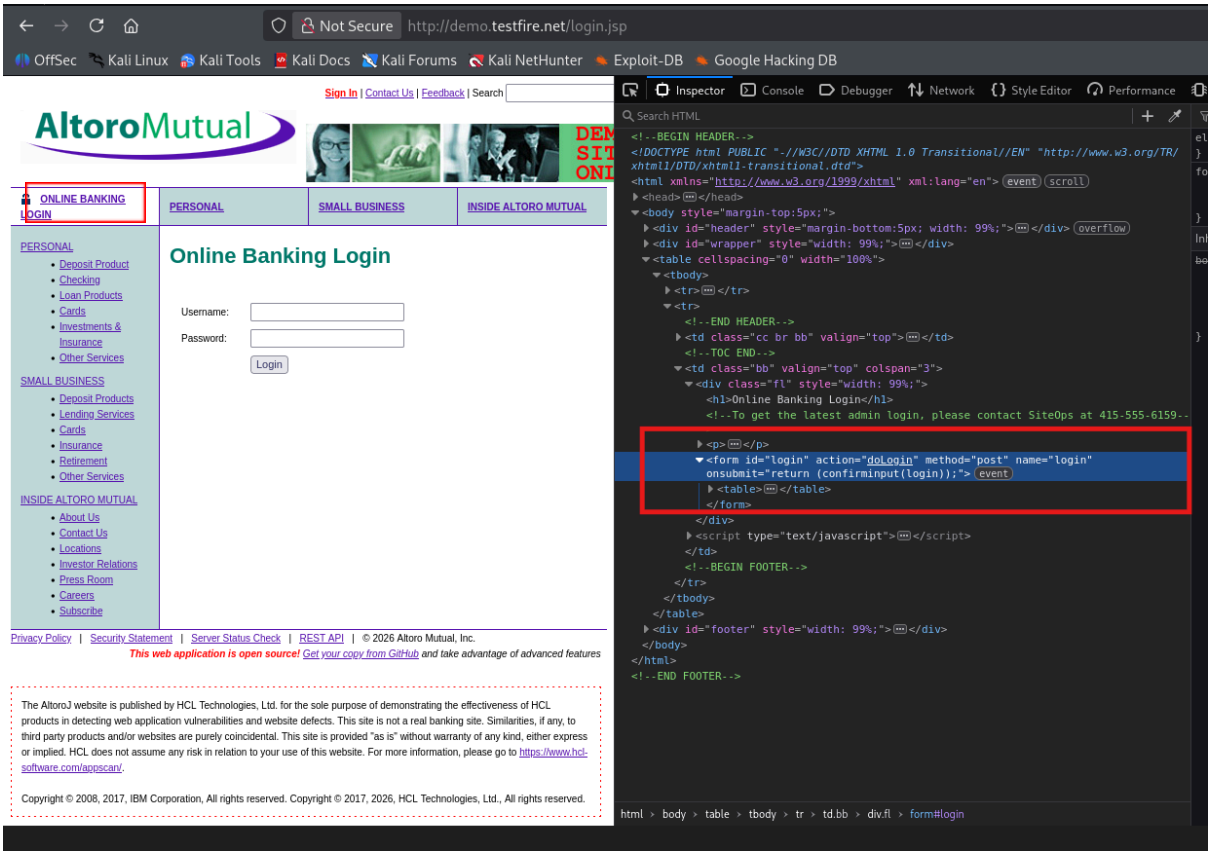


Fig 2:http://demo.testfire.net/feedback.jsp

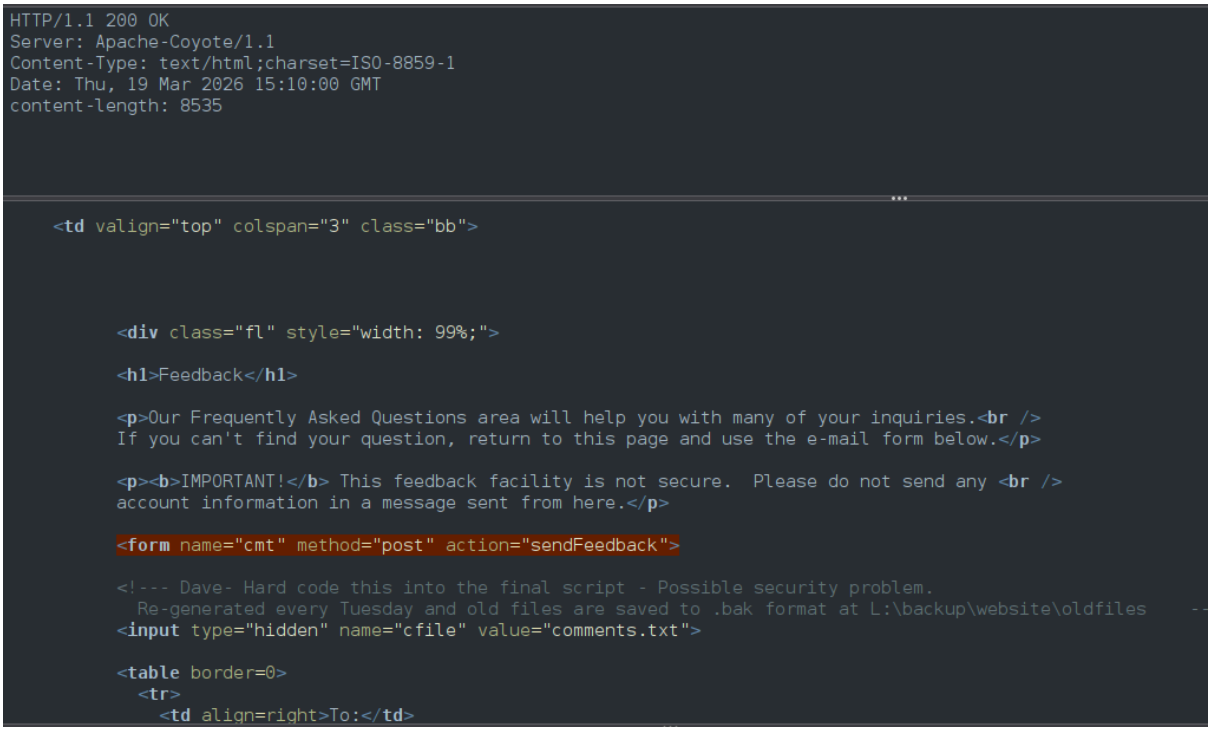


Fig 2: http://demo.testfire.net/feedback.jsp

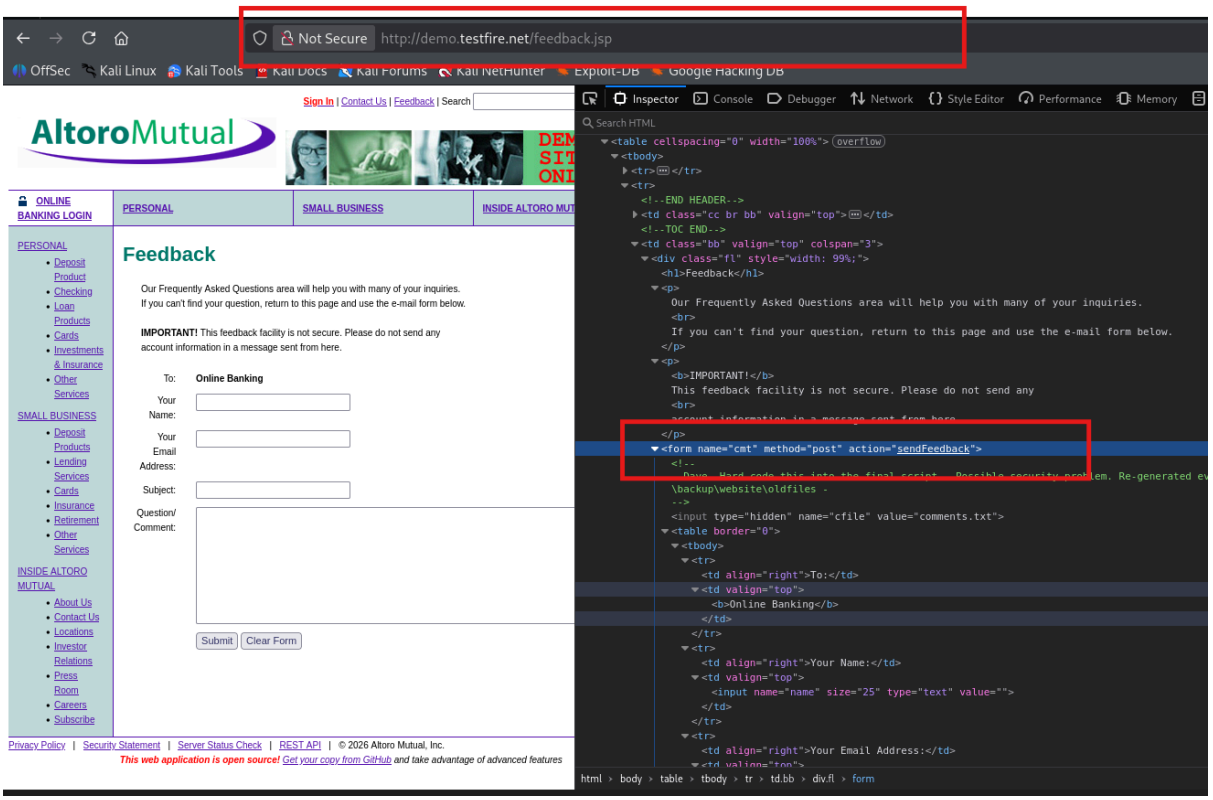
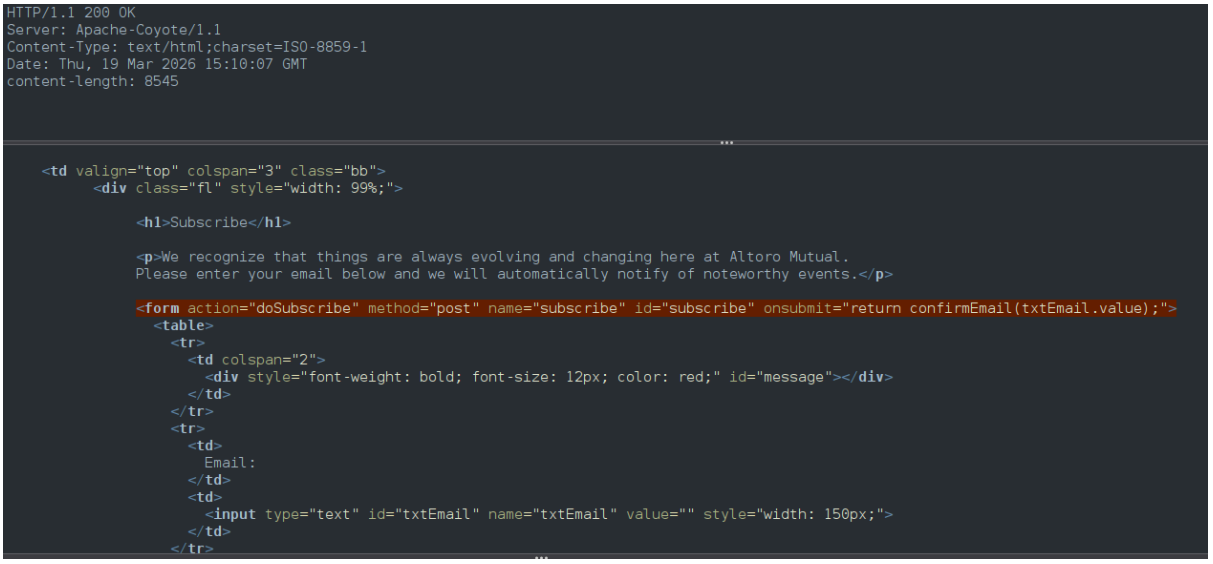
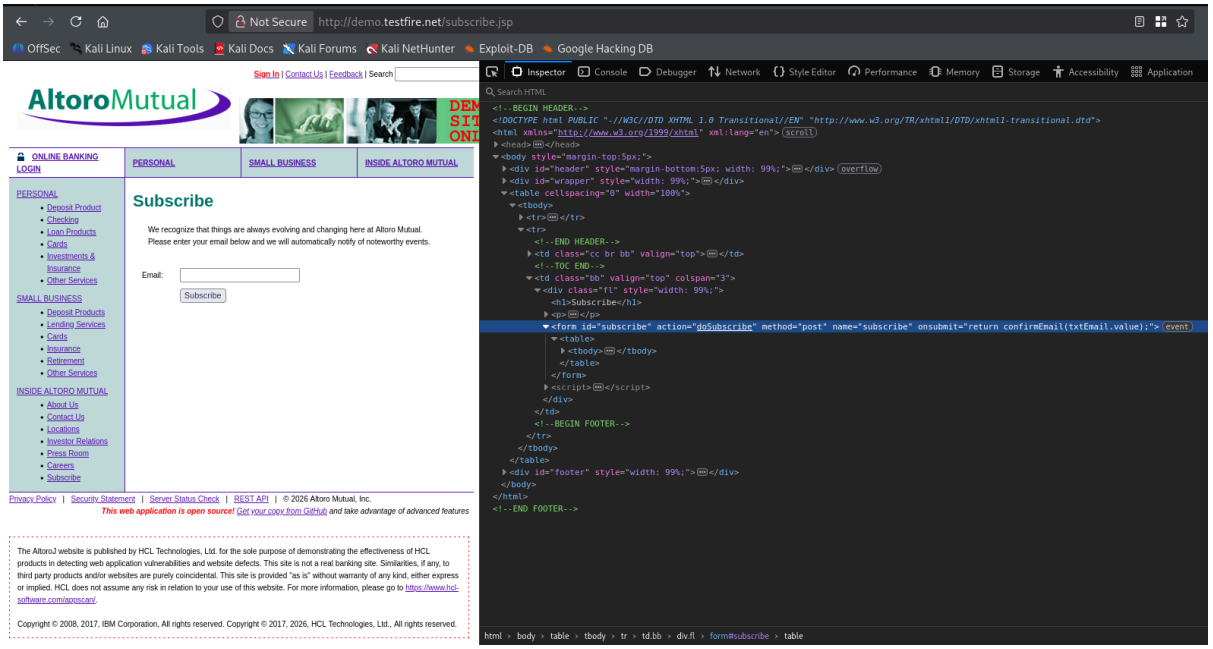


Fig 3: http://demo.testfire.net/feedback.jsp





3. Content Security Policy (CSP) Header Not Set

Reference No:	**Risk Rating:**
CWE ID :693 , WASC ID: 15	**High**
Tools Used:	
Zaproxy	
Vulnerability Description:	
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net http://demo.testfire.net/index.jsp?content=personal_deposit.htm http://demo.testfire.net/robots.txt	
Implications / Consequences of not Fixing the Issue	
Without CSP, the site remains highly vulnerable to XSS and data injection attacks, which can lead to sensitive data theft or total site defacement. This lack of control allows browsers to execute malicious, unauthorized scripts, potentially turning your platform into a distribution hub for malware.	
Suggested Countermeasures	
It is recommended to: • Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.	

References
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/

Proof of concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=6854AC52B22E8643EFCB98FB096D93B6; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:53 GMT
content-length: 9405

<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-trans

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >

<head>
    <title>Altoro Mutual</title>
  <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
  <link href="/style.css" rel="stylesheet" type="text/css" />
</head>
```

Fig 1: http://demo.testfire.net

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 8185
Date: Thu, 19 Mar 2026 15:09:28 GMT
```

```
<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >

<head>
    <title>Altoro Mutual</title>
  <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
  <link href="/style.css" rel="stylesheet" type="text/css" />
</head>
```

Fig 2: http://demo.testfire.net/index.jsp?content=personal_deposit.htm

```
HTTP/1.1 404 Not Found
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=A1162DE8280E67A59AB8D3668FF9783E; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 6958
Date: Thu, 19 Mar 2026 15:09:53 GMT
```

```
<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtm
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >

<head>
    <title>Altoro Mutual</title>
  <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
  <link href="/style.css" rel="stylesheet" type="text/css" />
</head>
<body style="margin-top:5px;">
```

Fig 3: http://demo.testfire.net/robots.txt

4. Missing Anti-clickjacking Header

Reference No:	Risk Rating:
CWE ID :1021 , WASC ID: 15	**High**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net http://demo.testfire.net/ http://demo.testfire.net/index.jsp?content=personal_deposit.htm	
Implications / Consequences of not Fixing the Issue	
Not fixing this leaves the site vulnerable to Clickjacking, where attackers overlay invisible layers to trick users into clicking unintended buttons. This can lead to unauthorized transactions, data theft, or account changes performed without the user's knowledge.	
Suggested Countermeasures	
It is recommended to: ● Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive	
References	
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options	

Proof Of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=6854AC52B22E8643EFCB98FB096D93B6; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:53 GMT
content-length: 9405

<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xh

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >


<head>
    <title>Altoro Mutual</title>
```

Fig 1: http://demo.testfire.ne

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:59 GMT
content-length: 9405

<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.c

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >

<head>
    <title>Altoro Mutual</title>
  <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
```

Fig 2: http://demo.testfire.net/

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 8185
Date: Thu, 19 Mar 2026 15:09:28 GMT

<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://ww

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >

<head>
    <title>Altoro Mutual</title>
```

Fig 3: http://demo.testfire.net/index.jsp?content=personal_deposit.htm

5. Sub Resource Integrity Attribute Missing

Reference No:	**Risk Rating:**
CWE ID :345 , WASC ID: 15	**Medium**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who has gained access to this server from injecting malicious content.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net/index.jsp?content=personal_investments.htm	
Implications / Consequences of not Fixing the Issue	

The site is vulnerable to Supply Chain Attacks, where a compromised external server can inject malicious scripts directly into the users' browsers. This can lead to silent data theft or malware distribution
Suggested Countermeasures
It is recommended to: ● Provide a valid integrity attribute to the tag.
References
https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Proof Of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:10:01 GMT
content-length: 8259

</div>

<div class="flp" style="width: 150px;">

<img src="images/p_investments.jpg" alt="Personal Investments"><br />

<span class="credit">
Whether you're looking for a short-term solution or a long-term investment strategy, Altoro Mutual off
<script src="http://demo-analytics.testfire.net/urchin.js" type="text/javascript">
      </script>
      <script type="text/javascript">
            _uacct = "1234abc";
            urchinTracker();
            </script>
</div>

    </td>

</div>
```

Fig 1: http://demo.testfire.net/index.jsp?content=personal_investments.htm

6. Cookie without SameSite Attribute

Reference No:	**Risk Rating:**
CWE ID :1275 , WASC ID: 13	**Low**
Tools Used:	
Zaproxy	
Vulnerability Description:	
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net http://demo.testfire.net/login.js%5D	

http://demo.testfire.net/robots.txt
Implications / Consequences of not Fixing the Issue
An adversary having knowledge of HTML can easily perform Clickjacking. Users visiting the page will see the iframe attached and in certain scenarios it might look like a legitimate form asking for username and password. It can lead to credential stealing.
Suggested Countermeasures
It is recommended to: ● Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
References
https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=6854AC52B22E8643EFCB98FB096D93B6; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:53 GMT
content-length: 9405
```

Fig 1: http://demo.testfire.net

```
HTTP/1.1 404 Not Found
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=C75D96238F85FBA53B7CAA793E15CD8F; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 6958
Date: Thu, 19 Mar 2026 16:02:52 GMT
```

Fig 2: http://demo.testfire.net/login.js%5D

```
HTTP/1.1 404 Not Found
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=A1162DE8280E67A59AB8D3668FF9783E; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 6958
Date: Thu, 19 Mar 2026 15:09:53 GMT
```

Fig 3: http://demo.testfire.net/robots.txt

7. http://demo.testfire.net/index.jsp?content=personal_investments.htm

Reference No:	**Risk Rating:**
CWE ID :829 , WASC ID: 13	**Low**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The page includes one or more script files from a third-party domain.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net/index.jsp?content=personal_investments.htm	
Implications / Consequences of not Fixing the Issue	
An adversary having knowledge of HTML can easily perform Clickjacking. Users visiting the page will see the iframe attached and in certain scenario it might look like a legitimate form asking for username and password. It can lead to credential stealing.	
Suggested Countermeasures	
It is recommended to: ● Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.	
References	
https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site	

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:10:01 GMT
content-length: 8259

<p>For more information about these products, please <a href="index.jsp?content=inside_contact.htm">contact Al
<p><i>This page was last updated on: 10/30/2006</i></p>
</div>

<div class="flp" style="width: 150px;">

<img src="images/p_investments.jpg" alt="Personal Investments"><br />

<span class="credit">
Whether you're looking for a short-term solution or a long-term investment strategy, Altoro Mutual offers a fu
<script src="http://demo-analytics.testfire.net/urchin.js" type="text/javascript">
    </script>
    <script type="text/javascript">
        _uacct = "1234abc";
        urchinTracker();
        </script>
</div>
        |
    </td>

</div>
```

Fig 1: http://demo.testfire.net/index.jsp?content=personal_investments.htm

8. Server Leaks Version Information via "Server" HTTP Response Header Field

Reference No:	**Risk Rating:**
CWE ID :497 , WASC ID: 15	**Low**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis Apache-Coyote/1.1	
Vulnerable URLs / IP Address	
http://demo.testfire.net http://demo.testfire.net/images http://demo.testfire.net/index.jsp?content=personal_deposit.htm	
Implications / Consequences of not Fixing the Issue	
Leaking version info through "Server" headers provides attackers with a pre-mapped list of vulnerabilities, allowing them to bypass the discovery phase and launch targeted exploits. This exposure identifies the exact tech stack, making it easier for automated bots to compromise the server using known, unpatched flaws.	
Suggested Countermeasures	
It is recommended to: ● Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details..	
References	
https://httpd.apache.org/docs/current/mod/core.html#servertokens	

https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=6854AC52B22E8643EFCB98FB096D93B6; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:53 GMT
content-length: 9405
```

Fig 1: http://demo.testfire.net

```
HTTP/1.1 302 Found
Server: Apache-Coyote/1.1
Location: /images/
Content-Length: 0
Date: Thu, 19 Mar 2026 15:09:54 GMT
```

Fig 2:http://demo.testfire.net/images

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 8185
Date: Thu, 19 Mar 2026 15:09:28 GMT
```

Fig 3: http://demo.testfire.net/index.jsp?content=personal_deposit.htm

9. X-Content-Type-Options Header Missing

Reference No:	**Risk Rating:**
CWE ID :693 , WASC ID: 15	**Low**
Tools Used:	
Zaproxy	

Vulnerability Description:
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Vulnerability Identified by / How It Was Discovered
Manual Analysis Apache-Coyote/1.1
Vulnerable URLs / IP Address
http://demo.testfire.net http://demo.testfire.net/index.jsp?content=personal_deposit.htm http://demo.testfire.net/style.css
Implications / Consequences of not Fixing the Issue
Without this header, browsers may ignore the declared file type and "guess" the content, allowing a simple text file to be executed as malicious JavaScript. This vulnerability, known as MIME-sniffing, enables attackers to bypass security filters and perform Cross-Site Scripting (XSS) attacks.
Suggested Countermeasures
It is recommended to: ● Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
References
https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=6854AC52B22E8643EFCB98FB096D93B6; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:53 GMT
content-length: 9405
...
<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >
```

Fig 1: http://demo.testfire.net

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 8185
Date: Thu, 19 Mar 2026 15:09:28 GMT
```

Fig 2:http://demo.testfire.net/index.jsp?content=personal_deposit.htm

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Accept-Ranges: bytes
ETag: W/"1251-1610554444000"
Last-Modified: Wed, 13 Jan 2021 16:14:04 GMT
Content-Type: text/css
Content-Length: 1251
Date: Thu, 19 Mar 2026 15:09:59 GMT
```

```
body, table, td, p  {
     color:#000000;
     font: 10px Verdana, Arial, Sans-Serif;
     line-height: 1.6;
}
img {
     border-style: none;
     border-width: 0px;
}
form {
     margin-top: 0;
     margin-bottom: 0;
}
ul, ol {
     margin-top: 2px;
     margin-bottom: 8px;
}
td, p {
     margin: 10px;
     padding: 3px 10px 3px 10px;
}
th {
     text-align: left;
}
```

Fig 3: http://demo.testfire.net/style.css

10. Information Disclosure - Suspicious Comments

Reference No:	**Risk Rating:**
CWE ID :615 , WASC ID: 13	**Informel**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The response appears to contain suspicious comments which may help an attacker. The following pattern was used: \bUSER\b and was detected in likely comment: "/* tell the user the job isn't open anymore */", see evidence field for the suspicious comment/snippet.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis /* tell the user the job isn't open	
Vulnerable URLs / IP Address	
http://demo.testfire.net/index.jsp?content=inside_jobs.htm http://demo.testfire.net/login.jsp	
Implications / Consequences of not Fixing the Issue	
Exposing internal logic via code comments provides attackers with insights into your application's behavior, revealing hidden entry points or logic flaws. This sensitive information leakage helps hackers map out the backend structure, making it much easier to craft targeted attacks or bypass security checks.	
Suggested Countermeasures	

It is recommended to:

- Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

References

https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
https://owasp.org/www-community/Security_Headers

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:10:14 GMT
content-length: 10765

        var sp = job.split(" : ");
        if (sp.length == 2 && jobs[sp[1]] && jobs[sp[1]] != "") {
            /* check if job exists */
            if (jobs[sp[1]][sp[0]] && jobs[sp[1]][sp[0]] != "") {
                document.location.href = "index.jsp?content="+jobs[sp[1]][sp[0]];
            } else {
                /* tell the user the job isn't open anymore */
                document.write("<h2 style='color:#ff0000'>We're sorry, but it appears the position for " + sp[0] + " in group " + sp[1] +
" is not open anymore</h2>");
            }
        }
    }
}

function getParameter(name) {
    var searchStr = document.location.search.substring(1);
    var params = searchStr.split('&');
    for (var i=0; i < params.length; i++) {
        nv = params[i].split('=');
        if (nv.length == 2 && nv[0] == name) {
            return nv[1];
        }
    }
```

Fig 1: http://demo.testfire.net/index.jsp?content=inside_jobs.htm

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:09:59 GMT
content-length: 8555
```

```
            <li><a id="MenuHyperLink17" href="index.jsp?content=inside_press.htm">Press Room</a></li>
            <li><a id="MenuHyperLink18" href="index.jsp?content=inside_careers.htm">Careers</a></li>
              <li><a id="MenuHyperLink19" href="subscribe.jsp">Subscribe</a></li>
        </ul>
    </td>
<!-- TOC END -->

   <td valign="top" colspan="3" class="bb">
          <div class="fl" style="width: 99%;">

          <h1>Online Banking Login</h1>

          <!- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
          <p><span id="_ctl0__ctl0_Content_Main_message" style="color:#FF0066;font-size:12pt;font-weight:bold;">

          </span></p>

          <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
            <table>
              <tr>
                <td>
                  Username:
                </td>
                <td>
                  <input type="text" id="uid" name="uid" value="" style="width: 150px;">
```

Fig 2:http://demo.testfire.net/login.jsp

11. Modern Web Application

Reference No:	**Risk Rating:**
CWE ID :497 , WASC ID: 15	**Informel**
Tools Used:	
Zaproxy	
Vulnerability Description:	
The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one. No links have been found while there are scripts, which is an indication that this is a modern web application.	
Vulnerability Identified by / How It Was Discovered	
Manual Analysis	
Vulnerable URLs / IP Address	
http://demo.testfire.net/disclaimer.htm?url=http://www.netscape.com http://demo.testfire.net/index.jsp?content=inside.htm http://demo.testfire.net/index.jsp?content=personal_deposit.htm	
Implications / Consequences of not Fixing the Issue	
Suggested Countermeasures	
● This is an informational alert and so no changes are required.	
References	

Proof of Concept:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Accept-Ranges: bytes
ETag: W/"2083-1610554444000"
Last-Modified: Wed, 13 Jan 2021 16:14:04 GMT
Content-Type: text/html
Content-Length: 2083
Date: Thu, 19 Mar 2026 15:10:08 GMT
```

```
<body bgcolor=#FFFFFF link="#5811B0" vlink="#5811B0" leftmargin="0" topmargin="0" marginwidth="0" marginheight="0">

  <center>
  <table width=90% border=0>
    <tr>
      <td>
        <p>This hyperlink allows you to access a third party website:
        <br /><br />
        <b><script>document.write(encodeURI(sDst));</script></b>
        <br /><br />
        Please read the privacy policy of the linked website, which
        may differ from the privacy policy of the Altoro Mutual website.
        <br /><br />
        Click OK to continue or Cancel to remain on altoromutual.com.
        </p>
        <a href="#" onclick="go();return false;"><img src="images/ok.gif" id="ok" alt="ok" border="0"></a>
        <a href="#" onclick="cl();return false;"><img src="images/cancel.gif" id="cancel" alt="cancel" border="0"></a>
      </td>
    </tr>
  </table>

  </center>
```

Fig 1:http://demo.testfire.net/disclaimer.htm?url=http://www.netscape.com

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Thu, 19 Mar 2026 15:10:00 GMT
content-length: 8400
```

```
<div class="fl" style="width: 67%;">

<h1>Inside Altoro</h1>

<p>In an industry characterized by change, Altoro Mutual is proud of its longevity. Altoro Mutual's success conti
service and product innovation.</p>

<h2>Part of a Corporate Family</h2>
<p>Altoro Mutual is a subsidiary of Altoro, a multi-state holding company located in the heart of Massachusetts.
communities for nearly 75 years. With nearly $20 billion in managed assets and over 7,000 employees, Altoro Mutua
United States. Altoro Mutual serves over 6.6 million customers in all 50 states, with more than 90 banking locati

<h2>We're Not Like Other Banks</h2>
<p>And you'll realize it right away. Altoro Mutual is about making things better for people ? our customers, empl
about our <a href="index.jsp?content=inside_community.htm">community programs</a> or to read our <a href="pr/comm
(PDF, 63KB)</a>.</p>

<p>Other Altoro Group sites: <a href="">Altoro Private Bank</a>, <a href="">Altoro Wealth & Tax</a></p>

</div>

<div class="flp" style="width: 150px;">

<img src="images/inside1.jpg" alt="Altoro Inside"><br />
```

Fig 2:http://demo.testfire.net/index.jsp?content=inside.htm

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Accept-Ranges: bytes
ETag: W/"1488-1610554444000"
Last-Modified: Wed, 13 Jan 2021 16:14:04 GMT
Content-Type: text/html
Content-Length: 1488
Date: Thu, 19 Mar 2026 15:10:06 GMT
```

```
        margin:0;
        background: #fafafa;
      }
    </style>
  </head>

  <body>
    <div id="swagger-ui">

    <script src="./swagger-ui-bundle.js"> </script>
    <script src="./swagger-ui-standalone-preset.js"> </script>
    <script>
    window.onload = function() {

      // Build a system
      const ui = SwaggerUIBundle({
        url: window.location.href.substr(0, window.location.href.lastIndexOf("\/") + 1) + "properties.json",
        dom_id: '#swagger-ui',
        deepLinking: true,
        presets: [
          SwaggerUIBundle.presets.apis,
          SwaggerUIStandalonePreset
        ],
        plugins: [
```

Fig 3: http://demo.testfire.net/swagger/index.html

----------EOF----------